応用情報技術者試験　マネジメント系　#16

システム監査

用語集まとめ ― 過去問10回分（令和3〜7年度）とシラバスの用語例から



全体像 シラバスの二つの項目を、4章に分けて読む

1 監査の種類と基準
会計・業務・システム監査・保証型と助言型・システム監査基準とシステム管理基準・ガバナンス／マネジメント／コントロール・倫理と独立性

2 監査の流れと技法
監査計画とリスクアプローチ・予備調査と本調査・監査手続と監査証拠・監査調書・チェックリスト法〜ウォークスルー法・CAAT

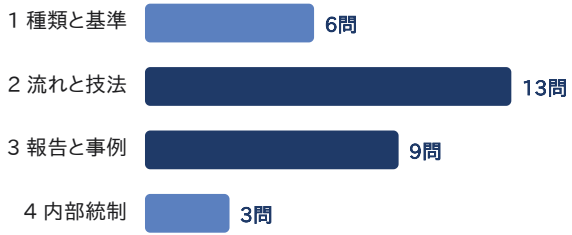
3 報告・フォローアップと関連法規
指摘事項・改善提案と改善計画・フォローアップ・他の監査との連携・刑法や個人情報保護法など

4 内部統制と IT ガバナンス
四つの目的と六つの基本的要素・関係者の役割・全般統制と業務処理統制・職務分掌と限界・JIS Q 38500・COBIT

午前での出方	
問題数	毎回 **3問**（問58〜問60）。10回で31問
中心	**監査の流れ**（予備調査・監査調書・フォローアップ）と**監査技法**で7割
同じ問題の再出題	フォローアップ（R3春60＝R7秋59）・監査手続（R4秋59＝R7春59）・予備調査（R5春58≒R6秋59）・ウォークスルー法は3回
基準の版	R5秋までは平成30年版、R6春からは**令和5年版**のシステム監査基準を指定

この資料の読み方：選択肢の誤りはほぼ二つの型。**「監査人がやってはいけないこと」**（改善計画を作る・指示する）と、**用語と説明のすり替え**（監査調書と報告書、所見と正当な注意）。

いちばん多いのは監査の流れと技法。毎回1〜2問はここから出る



令和3年度春期〜令和7年度秋期の31問を、章ごとに数えた（同じ問題も1問ずつ数えた）

よく出る型	中身	過去問
監査調書	役割・書くこと・保管	R4春59・R5秋58・R6春58
予備調査・手続	実態の把握・十分かつ適切な証拠	R5春58・R6秋59・R4秋59・R7春59・R4春60
監査技法	ウォークスルー法・インタビュー法・CAAT	R3秋59・R6秋58・R7春58・R5春59・R5秋59
フォローアップ	監査人がすること・しないこと	R3春60・R3秋60・R6秋60・R7秋59
基準と用語	監査基準の意義・GMC の視点・独立性	R4秋60・R6春59・R7秋60・R7秋58
指摘事項	基準に合わない状況を選ぶ	R3春58・R4秋58
内部統制	役割・IT への対応・業務処理統制	R5春60・R5秋60・R6春60

第1章

監査の種類と基準

会計監査・業務監査・システム監査 ／ 内部と外部・法定と任意 ／ 保証型と助言型 ／ システム監査基準とシステム管理基準 ／ ガバナンス・マネジメント・コントロール ／ 倫理と独立性



監査は「何を見るか」と「誰が・なぜやるか」の二つの軸で分ける

何を見るか	中身
会計監査	財務諸表などの会計記録が正しいか
業務監査	会計以外の業務が有効・効率的に行われているか
経営監査	経営の方針・戦略・組織が妥当か
システム監査	情報システムのリスクに適切に対応しているか
情報セキュリティ監査	情報セキュリティのコントロールが適切か
個人情報保護監査	個人情報の取扱いが法令・JIS Q 15001 に合うか
コンプライアンス監査	法令・規程・行動指針が守られているか
マネジメントシステム監査	ISO の規格に適合し有効か（指針は JIS Q 19011）

誰が・なぜ	中身
内部監査	組織内の監査部門。経営者の直属に置く
外部監査	外部の独立した専門家（監査法人など）
法定監査	法律で義務（金融商品取引法監査・会社法監査）
任意監査	組織が自ら行う。システム監査の多くはこれ
立入監査	現場（委託先も）に立ち入って行う

> システム監査の目的は、**独立かつ客観的な立場**の監査人が検証・評価し、**保証や助言**を行って、組織の目標達成と**利害関係者への説明責任**に役立てること。

🤝 保証型は「適切です」と言う監査、助言型は「こう直そう」と言う監査

保証型
証拠を客観的に評価し、結論や意見を表明。利害関係者に一定の保証を与える

助言型
問題点について、改善の助言・提案・相談。依頼者の求めに応じることが多い

> 二つは**排他的ではない**。組み合わせてもよい。どちらで行うかは**監査の依頼者のニーズ**で決める。

R3秋 問57：保証型と助言型の実施（情報セキュリティ監査）

	選択肢の中身	判断
ア	保証型から始め、保証後に助言型へ切り替えなければならない	順番の決まりはない
イ	二つは**排他的**で、どちらかに決める	組み合わせてよい
ウ	依頼者のニーズでなく**監査人の責任**で決める	ニーズで決める
エ	**不特定多数の情報を扱うシステムは保証型を定期実施し、結果を開示**	**正解**

📏 監査基準は「監査人のルール」、管理基準は「評価の物差し」

経済産業省の基準	役割
システム監査基準	監査人の**行為規範**。監査の品質を確保し、有効かつ効率的な監査を実現する
システム管理基準	ガバナンス・マネジメント・コントロールを評価するときの**判断の尺度**
情報セキュリティ監査基準	情報セキュリティ監査の行為規範
情報セキュリティ管理基準	情報セキュリティ監査の判断の尺度（JIS Q 27001・27002 が基）
システム管理基準追補版	財務報告に係る IT 統制ガイダンス（J-SOX 向け）

> システム監査基準は平成30年版 → **令和5年版**。令和5年版は「監査人の倫理」と12の基準から成る。

R4秋 問60：システム監査基準の意義

	選択肢の中身	本当は
ア	**品質を確保し有効かつ効率的な監査を実現する行為規範**	**正解**
イ	監査人が持つべき知識・技能の水準	そういう基準ではない
ウ	GMC を点検・評価する判断の尺度	システム管理基準
エ	情報システムの管理で共通に留意すべき基本事項	システム管理基準

令和5年版では、監査の対象は「ガバナンス・マネジメント・コントロール」

ガバナンス
経営陣が方向付け・モニタリング

マネジメント
方向に沿って計画・構築・運営・監視（PDCA）

コントロール
リスクを低減する一つ一つの管理手段

R6春 問59：マネジメント・コントロールと、あと一つは**ガバナンス（ア）**。コンプライアンス・サイバーレジリエンス・モニタリングではない。

R7秋 問60：“コントロールの視点”から行う項目

	項目	視点
ア	IT 投資の結果が適切なリターンを生んでいるか	ガバナンス
イ	**異常なアクセスを検出したとき適時に対処・報告しているか**	**コントロール（正解）**
ウ	セキュリティ対策が PDCA で管理されているか	マネジメント
エ	新技術を経営戦略のために活用できているか	ガバナンス

経営の目線（投資・戦略）＝ガバナンス、**回しているか**（PDCA）＝マネジメント、**個々の手段が働くか**＝コントロール。

評価の観点：どの性質を確かめる項目かを見分ける

観点	確かめること
準拠性	法令・規程・基準・契約に従っているか
有効性	ねらった目的や効果を達成しているか
効率性	資源に見合う成果を無駄なく出しているか
信頼性	障害が少なく、正しく処理を続けられるか
可用性	必要なときに使えるか
機密性・完全性	許された人だけが使えるか ／ データが正しく保たれるか

R3春 問59：マスタファイル管理の監査項目のうち可用性

	監査項目	観点
ア	**サーバを二重化し、耐障害性を高めている**	**可用性（正解）**
イ	複数件まとめて検索・加工する機能	効率性・使いやすさ
ウ	メンテナンスは特権アカウントの人だけ	機密性
エ	データ入力チェック機能	完全性

「二重化」「耐障害性」は可用性、「権限を限る」は機密性、「チェック機能」は完全性の目印。

📜 監査人の倫理と独立性：用語と説明のすり替えに注意する

用語（令和5年版）	意味
独立性	第三者から不当な影響や圧力等を受けていない**状態**。外観上と精神上
客観性	偏りや利害の対立なしに判断すること
誠実性	常に正直な態度で、強い意志をもって適切に行動
正当な注意	監査人として当然払うべき注意
正当な懐疑心	何事も当然とせず、疑ってみる・確認してみる心
所見	発見したこと、又はそれに基づく考えや意見
秘密の保持	業務上知った秘密を漏らさない・自分の利益に使わない

R7秋 問58：用語の説明として適切なもの

	選択肢の説明	本当は
ア	所見＝誰がやっても同じ結果になること	所見は「発見と意見」
イ	正当な懐疑心＝客観性を保つ精神的な態度	精神上の独立性に近い
ウ	正当な注意＝発見に基づく考えや意見	それは所見
エ	**独立性＝不当な影響や圧力を受けていない状態**	**正解**

外観上の独立性：自分が**開発に参加したシステム**を監査すると損なわれる。監査部門は対象部門から切り離し、**経営者の直属**に置く。

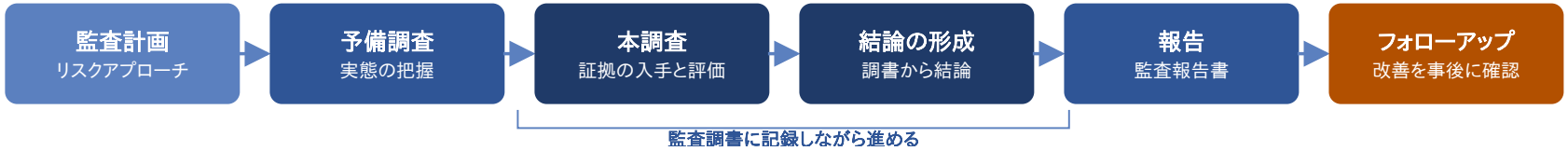
第2章

監査の流れと技法

監査計画とリスクアプローチ ／ 予備調査と本調査 ／ 監査手続と監査証拠 ／ 監査調書と所見 ／ チェックリスト法・インタビュー法・ウォークスルー法 ／ CAAT



監査は「計画 → 予備調査 → 本調査 → 結論 → 報告 → フォローアップ」



監査計画の種類	中身
中長期計画	数年先までの方針（重点テーマ・体制・人材）
年度計画	1年間の監査対象・時期・担当・予算
個別監査計画	監査対象ごとの目的・範囲・手続・**スケジュール**

リスクアプローチ

リスクの大きさ（**起こりやすさ × 影響**）に基づいて、監査の対象・時間・人員の優先度を決める。限られた資源をリスクの高いところに集中させる

監査の目的・対象範囲・権限と責任は、**内部監査規程**（内部）や**システム監査委託契約書**（外部）で明確にしておく。

予備調査は「実態をつかむ」、本調査は「証拠を集める」

	予備調査	本調査
目的	監査対象の**実態を把握**し、本調査の手続を決める	結論を裏付ける**十分かつ適切な監査証拠**を入手
方法	事務手続・マニュアルの閲覧、聞き取り、アンケート	監査手続（技法）の実施
範囲	対象先に**限らない**（関係部門・委託先も）	監査計画で決めた範囲
現地	**必ず行く必要はない**	必要に応じて現地調査

R6秋 問59（≒ R5春 問58）：予備調査の記述

	選択肢の中身	判断
ア	**事務手続やマニュアルで業務内容・業務分掌・体制を把握**	**正解**
イ	**必ず**現地に赴いて実施	言い過ぎ
ウ	結論を裏付ける十分な証拠を入手	本調査
エ	範囲は対象先**だけに限定**	限らない

> R5春 問58 は平成30年版の同じ問題で、選択肢の並びが違い**正解はイ**。記号でなく中身で覚える。

監査手続は「十分かつ適切な証拠を入手するための手順」

R4秋 問59 ＝ R7春 問59：“監査手続”とは

	選択肢の中身	本当は
ア	監査計画の立案や進捗管理の手順	監査の管理
イ	報告書に結論や指摘事項を書く手順	報告
ウ	**十分かつ適切な証拠を入手するための手順**	**正解**
エ	監査チームを編成する手順	計画の体制

一つの監査目的に、**複数の監査手続を組み合わせる**のが普通（R4春 問60 エ）。

R4春 問60：監査証拠の記述のうち“適切でない”もの

	選択肢の中身	判断
ア	**アジャイル開発では、体裁の整った管理文書だけが監査証拠になる**	**適切でない（正解）**
イ	委託先の第三者の保証報告書に依拠できれば現地調査を省略できる	適切
ウ	本調査の前に予備調査で実態を把握	適切
エ	一つの目的に複数の手続を組み合わせる	適切

監査証拠は、資料・データ・証言・**監査証跡**（ログなど）の全て。監査のためだけの文書づくりを現場に求めない。

監査調書は「結論に至った過程」と「結論の根拠」の記録

令和5年版の説明
実施した監査手続、入手した監査証拠及び監査人が到達した結論の記録。監査の結論に至った過程を明らかにし、**結論を支える合理的な根拠**とする

誤りの選択肢（R4春59・R5秋58）	正しくは
全て社内で公開すべき	秘密を守る（関係者に限る）
バックアップは作るべきでない	なくさないよう適切に保管
事実だけ書き、所見は書かない	**事実と所見**を書く
作成は任意／ただの備忘録	作成は**必須**。正式な記録
チームでも共有しない	監査チームでは共有する

R6春 問58：監査調書の説明（ほかの文書とのすり替え）

	選択肢の中身	本当は
ア	**結論に至った過程を明らかにし、合理的な根拠とする記録**	**監査調書（正解）**
イ	依頼者に出す、概要と結論を書いた要約版の報告書	監査報告書
ウ	監査対象ごとの具体的なスケジュール	個別監査計画
エ	中長期の方針を明らかにする文書	中長期計画

> 監査人が**自分で作る記録**が監査調書、システムが残す処理の記録が**監査証跡**。

監査技法：何をどう確かめるかで名前が決まる

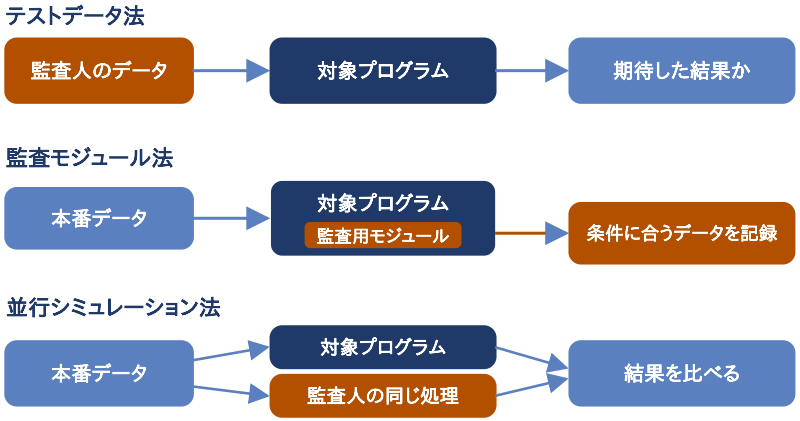
技法	中身
チェックリスト法	**監査人が作った**質問の一覧に、監査対象部門が回答
ドキュメントレビュー法	文書・記録を入手して閲覧・点検
インタビュー法	関係者に**直接、口頭で**問い合わせ回答を得る
ウォークスルー法	データの**生成から活用まで**のプロセスとコントロールを**追跡**
突合・照合法	関連する記録どうしを突き合わせる
現地調査法	現場に行って自ら観察・調査
統計的サンプリング	確率に基づいて抜き出し、全体を推定

R5春 問59：技法の記述として適切なもの

	選択肢の中身	判断
ア	**インタビュー法：直接、口頭で問い合わせ回答を入手**	**正解**
イ	現地調査法は業務時間**外に**実施しなければならない	そんな決まりはない
ウ	CAAT は**専用ソフト**によらなければならない	汎用ソフトも使える
エ	チェックリストは**監査対象部門が作る**	作るのは監査人

ウォークスルー法は R3秋59・R6秋58・R7春58 と**3回**出た。決め手は「**生成から活用まで**」「**追跡**」。

CAAT：データ・プログラム・組み込みのどれを監査人が用意するかで分ける



技法	監査人が用意するもの／分かること
テストデータ法	**データ**を用意。入力チェックや処理の正しさ
監査モジュール法	対象に**監査用モジュールを組み込む**。本番中に継続的にデータ収集
並行シミュレーション法	同じ処理をする**別のプログラム**。論理の正確性
監査ソフトウェア・データ分析	全件から例外（値引取引など）を抽出・集計
ペネトレーションテスト法	実際に侵入を試み、セキュリティの弱点を確かめる

> CAAT ＝コンピュータ支援監査技法。大量のデータの検索・抽出・計算をコンピュータで行う。**汎用ソフト（表計算など）も可**。

「漏れなく・重複なく」は、元の伝票と入力結果を突き合わせて確かめる



確かめたい性質ごとに手続が違う。**網羅性**（漏れ・重複）→ 照合、**正確性**（値の形式）→ テストデータ法、**正当性**（承認済みか）→ 承認の記録。

R5秋 問59：受注伝票の入力が漏れなく重複なく行われているか

	監査手続	確かめる性質
ア	例外取引データを抽出し承認の記録を確かめる	正当性
イ	論理・フォーマットチェックをテストデータ法で	正確性
ウ	**プルーフリストと受注伝票の照合印を確かめる**	**網羅性（正解）**
エ	並行シミュレーション法でプログラムの論理	処理の正確性

第3章

報告・フォローアップと関連法規

指摘事項の選び方 ／ 改善提案と改善計画 ／ フォローアップで監査人がすること・しないこと ／ BCP・アジャイル開発・受入テストの監査 ／ 他の監査との連携と法規









⚠️ 指摘事項は「基準に合っていない状況」。基準どおりなら指摘しない

R3春 問58：マルウェア対策の監査（情報セキュリティ管理基準）

	判明した状況	判断
ア	Web ページをスキャンしている	適切
イ	感染を想定して BCP を策定	適切
ウ	**スキャンした上で、認可していないソフトを使用**	**指摘（正解）**
エ	脆弱性の情報を集め、修正コードを適用	適切

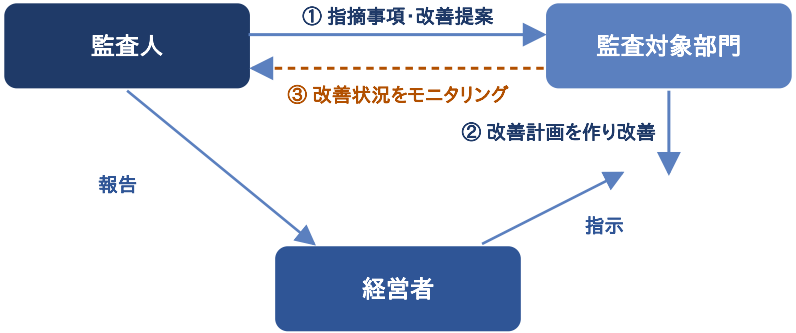
スキャンしていても、**認可されていないソフトの使用**そのものが基準に反する。

R4秋 問58：ISMS 内部監査（JIS Q 27001）

	判明した状況	判断
ア	USB メモリを手順に従って許可	適切
イ	誤廃棄事故を規定どおり報告	適切
ウ	スパイウェアを検知し駆除	適切
エ	**リスクアセスメントの後に受容基準を決めた**	**指摘（正解）**

リスク受容基準は、リスクアセスメントの**前に**決める。後から決めると結果に合わせた基準になる。「**順番が逆**」も指摘の対象。

フォローアップで監査人は「確かめる」だけ。改善するのは監査対象部門



改善の**指示**は経営者、改善**計画**と**実施**は監査対象部門。監査人が手を出すと、自分の仕事を自分で監査することになり**独立性**が崩れる。

過去問	問われ方と正解
R3春60＝R7秋59	適切なもの → **改善状況をモニタリング（ウ）**。指示する・プロジェクトを管理する・計画を作る、は誤り
R3秋60	**不適切な**もの → **監査人が改善計画を作成（ウ）**。経営者のリスク受容で改善しない（ア）は適切
R6秋60	フォローアップの説明 → **改善提案の実施状況の情報を集めモニタリング（ウ）**。終わらなかった項目の追跡調査（エ）ではない

フォローアップの問題は**4回とも正解がウ**だった。記号でなく、「モニタリング」という言葉で選ぶ。

対象業務の監査：BCP・アジャイル開発・ユーザ受入テスト

R4春 問58：BCP の監査で適切な状況	
ア	**緊急連絡先リストを作り、最新版に更新（正解）**
イ	重要書類を複製せず1か所に集中保管 → 別の場所にも保管する
ウ	全業務に優先順位なしで同じ水準 → 重要業務から優先
エ	平時は従業員に非公開 → 周知して訓練する

R3秋 問58：アジャイル開発の監査の着眼点	
ウ	**実装した機能を利害関係者にデモし、フィードバックを得る（正解）**
ア	工程ごとの完了基準で逐次進める → ウォータフォール型
イ	情報システム部門の要員だけで構成 → 利用部門も入る
エ	全部終わってからリリース計画 → こまめにリリース

R7春 問60：ユーザ受入テストのチェックポイント（システム管理基準 令和5年）

	チェックポイント	本当は
ア	**業務要件の反映を、利用者の立場からテスト**	**受入テスト（正解）**
イ	稼働後に IT 戦略の目標を達成したか	事後評価
ウ	中間成果物も含めて全構成要素をレビュー	開発途中のレビュー
エ	移行後に本番環境が使えるかレビュー	移行の確認

システム管理基準は、企画・開発（アジャイル含む）・運用・保守・廃棄・外部サービスの利用まで、**プロセスごとの着眼点**を示している。

他の監査と連携し、法令に反する状況も指摘する

他の監査	中身
金融商品取引法監査	公認会計士・監査法人が財務諸表と内部統制報告書を監査
会社法監査	監査役（業務と会計）と会計監査人
内部監査	内部監査人。国際的な枠組みは IPPF（IIA）

刑法のコンピュータ犯罪	
電磁的記録不正作出及び供用	事務処理を誤らせる目的でデータを不正に作る・使う
電子計算機損壊等業務妨害	壊す・不正な指令で動かなくして業務を妨害
電子計算機使用詐欺	虚偽のデータで財産上の不法な利益を得る

法規・制度	監査で見るところ
不正アクセス禁止法	他人の ID・パスワードの無断使用・提供
個人情報保護法・マイナンバー法	利用目的・安全管理・第三者提供 ／ 特定個人情報
JIS Q 15001・プライバシーマーク	個人情報保護の仕組み ／ その認定制度
JIS Q 27001・ISMS 適合性評価	情報セキュリティの仕組み ／ その認証制度
不正競争防止法	営業秘密（秘密管理性・有用性・非公知性）
電子帳簿保存法・電子署名法	国税の帳簿の電子保存 ／ 電子署名の効力
労働者派遣法	派遣と請負の区別（偽装請負）

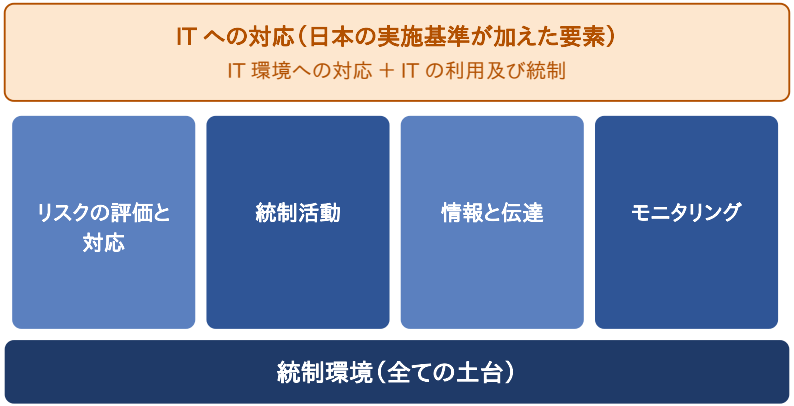
第4章

内部統制と IT ガバナンス

四つの目的と六つの基本的要素 ／ 関係者の役割 ／ IT への対応・全般統制と業務処理統制 ／ 職務分掌・モニタリング・限界 ／ J-SOX ／ JIS Q 38500・COBIT・CIO



内部統制は四つの目的と六つの基本的要素。土台は統制環境



四つの目的

業務の有効性及び効率性 ／ 報告の信頼性 ／ 事業活動に関わる法令等の遵守 ／ **資産の保全**（日本が追加）

要素	中身
統制環境	組織の気風。誠実性と倫理観・経営者の姿勢・組織構造
リスクの評価と対応	リスクを識別・分析・評価し、対応を選ぶ
統制活動	指示を実行するための方針と手続（承認・照合・職務分掌）
情報と伝達	必要な情報を正しく伝える（内部通報も）
モニタリング	日常的モニタリングと独立的評価（内部監査）

米国の COSO は要素が五つ。日本はこれに「IT への対応」を加えて**六つ**。

関係者の役割：責任・方針・監視・評価の主語を取り違えない

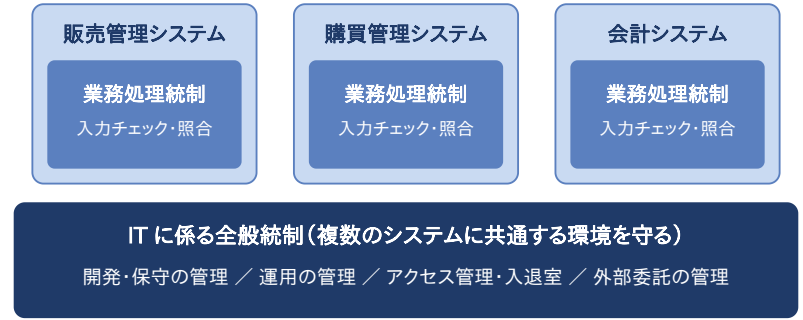
人	役割と責任
経営者	整備と運用に**最終的な責任**。内部統制報告書を作る
取締役会	整備と運用の**基本方針を決定**し、経営者を監督
監査役等	職務執行の監査の一環として、**独立した立場から監視・検証**
内部監査人	**モニタリングの一環**として検討・評価し、改善を促す
組織内のその他の者	自分の業務の中で、内部統制の整備と運用の役割を担う

R5春 問60：役割と責任の記述として適切なもの

	選択肢の中身	本当は
ア	**株主**が最終的な責任を持つ	経営者
イ	**監査役**が基本方針を決定する	取締役会
ウ	**経営者**が独立した立場から監視・検証する	監査役等
エ	**内部監査人がモニタリングの一環として評価し改善を促す**	**正解**

内容は正しい文で、**主語だけ入れ替えて**誤りにしている。役割の文から主語を言えるようにする。

IT の統制は、土台の全般統制と、業務ごとの業務処理統制の二階建て



R6春 問60：業務処理統制に当たるもの	
ウ	**販売管理システムの入力データの正当性チェック機能（正解）**
ア・イ・エ	入退室管理・開発の委託先の選定手続・ファイアウォールの運用 → どれも**全般統制**

R5秋 問60：IT への対応（実施基準）		
	選択肢の中身	**判断**
ア	IT 環境は企業**内部に限られた**範囲	外部も含む
イ	**IT の統制は全般統制と業務処理統制から成る**	**正解**
ウ	自動化していれば有効と**評価される**	それだけでは言えない
エ	手作業だけなら**直ちに不備**	不備とは限らない

> 全般統制が弱いと、業務処理統制のプログラムが勝手に変えられるおそれがある。だから**全般統制が業務処理統制の前提**。

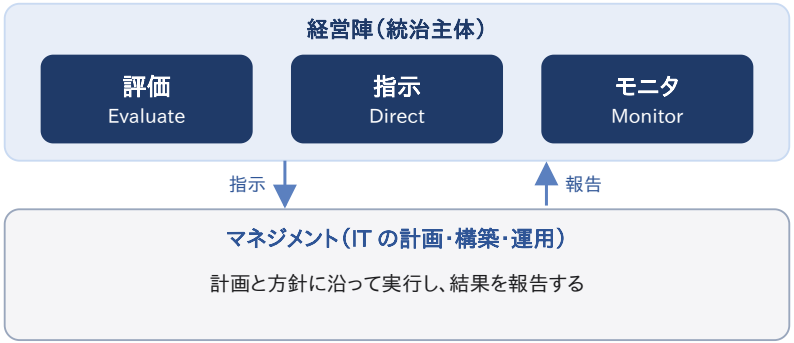
🔑 職務分掌で互いにけん制する。ただし共謀には効かない（内部統制の限界）

内部統制を実現する取組み	中身
業務プロセスの明確化	業務の流れ・担当・使う情報を業務フロー図などで明らかにする
職務分掌	承認・実行・記録・保管を**別の人**に分ける
実施ルールの設定	規程・手順・基準を決めて文書にする
チェック体制の確立	承認・照合・上司の確認・内部監査

> 例：同じ人が受注の**入力と承認**の両方をできる → 権限を分ける。開発者が本番環境を直接変更できないようにするのも職務分掌。

用語	中身
内部統制の限界	判断の誤り・不注意・**共謀**・想定外の取引・**経営者による無視**・費用と便益の制約。絶対的な保証はできない
日常的モニタリング	業務の中で行う確認や照合
独立的評価	業務から独立した視点（内部監査など）
CSA	担当部門が自分たちの統制を**自ら**評価
J-SOX	金融商品取引法の内部統制報告制度。経営者が評価し、監査法人が監査
ERM	全社的リスクマネジメント（COSO）。戦略と結び付けて管理

👑 IT ガバナンス：経営陣が IT を「評価・指示・モニタ」する



JIS Q 38500 の六つの原則：**責任・戦略・取得・パフォーマンス・適合・人間行動**。

用語	中身
IT ガバナンス	取締役会等が IT の利活用のあるべき姿（IT 戦略と方針）を示し、実現させる活動
コーポレートガバナンス	企業全体の経営を規律し監視する仕組み（企業統治）
COBIT	ISACA の IT ガバナンスと IT マネジメントのフレームワーク
PRM-IT	IBM の IT プロセスの参照モデル
成熟度モデル	プロセスの成熟の段階（0〜5）で評価
CIO・CISO	最高情報責任者（IT 戦略）／ 最高情報セキュリティ責任者
データガバナンス	データの品質・セキュリティ・利用のルールを全社で管理

システム監査・情報セキュリティ監査・ソフトウェア資産管理は、**IT ガバナンスを実現するための取組み**。

まとめ：迷いやすい組と、見分ける一言

組	見分ける一言
保証型・助言型	「適切です」と保証する ／ 改善を助言する。排他的でなく、依頼者のニーズで決める
システム監査基準・システム管理基準	監査人の行為規範 ／ 判断の尺度（情報セキュリティも監査基準と管理基準の組）
ガバナンス・マネジメント・コントロール	経営の方向付け（投資・戦略） ／ PDCA で回す ／ 個々の管理手段
独立性・客観性・正当な注意・正当な懐疑心・所見	影響を受けない状態 ／ 偏らない判断 ／ 当然払う注意 ／ 疑ってみる心 ／ 発見と意見
中長期計画・年度計画・個別監査計画	数年の方針 ／ 1年の対象と時期 ／ 対象ごとの手続とスケジュール
予備調査・本調査	実態の把握（現地は必須でない・範囲を限らない） ／ 十分かつ適切な証拠の入手
監査手続・監査証拠・監査証跡	証拠を入手する手順 ／ 結論を裏付ける情報 ／ システムが残す処理の記録
監査調書・監査報告書	結論に至った過程と根拠（事実と所見、必須、保管） ／ 依頼者に出す報告
チェックリスト・インタビュー・ウォークスルー	監査人が作った質問に回答 ／ 口頭で質問 ／ 生成から活用まで追跡
テストデータ・監査モジュール・並行シミュレーション	データを用意 ／ プログラムに組み込む ／ 同じ処理を別に作って比べる
網羅性・正確性・正当性の確認	伝票とプルーフリストの照合 ／ テストデータ法 ／ 承認の記録
改善提案・改善計画・フォローアップ	監査人が出す ／ 監査対象部門が作る ／ 監査人が改善状況をモニタリング
経営者・取締役会・監査役等・内部監査人	最終責任 ／ 基本方針の決定 ／ 独立した立場で監視・検証 ／ モニタリングの一環で評価
全般統制・業務処理統制	共通の環境（開発・運用・アクセス・委託） ／ 業務システムの中（入力チェック）
日常的モニタリング・独立的評価・CSA	業務の中で ／ 業務から独立して（内部監査） ／ 担当部門が自ら